

GB17859 和 GB/T18336

等级保护两个标准的关系

北京天融信公司 苑向兵

摘 要 GB17859 和 GB/T18336 是中国实行信息安全等级保护的两个重要标准。本文从历史沿革和具体内容两个方面深入分析了它们之间的关系,明确了两者之间并不存在矛盾和不相容的问题,它们的有机结合将为等级保护政策顺利实施提供有力的保证。

关键词 等级保护 TCSEC CC GB17859 GB/T18336

2003 年中共中央办公厅、国务院办公厅转发的 27 号文件和 2004 年 9 月中央四办联合发布的 66 号文件出台以后,等级保护政策的实施工作进入了实质的推进阶段。按照 66 号文件的安排,到 2005 年 9 月份应该推出一系列相关的法规、办法、指南等。以目前的情况来看,这个阶段的计划基本肯定要向后推延。作为等级保护工作的重中之重《管理办法》、《实施指南》、《评估指南》等法规的制定,很明显遇到了一定的困难。等级保护的思想确立,最早可以追溯到 1994 年的《中华人民共和国信息系统安全保护条例》,人们都会问:经历了这么多年酝酿,现在等级保护的配套法规还是难产,其根源是什么?

诚然,我国的信息安全标准研究,与国际上信息化水平较高的国家还存在不小的差距。但笔者认为,目前的问题直接与很多有关的人对 GB 17859 和 GB/T 18336 两个国家标准的本质理解不到位相关。其中比较有代表性的想法是:两个标准不相容,关系难以调和;GB17859 已经过时,等级保护应该遵从最新的国际公认标准。

实际上,这两个标准之间没有任何不相容之处,它们完全可以共存,并有效结合。要正确认识等级保护的两个国标,关键在于一要弄清两个标准的渊源关系,二要弄清两个标准内容上各自的特点和差异。

一、GB17859 与 GB/T18336 的渊源

从起源上说,GB17859 的制定主要参考了美国的 TCSEC,而 GB/T 18336 则直接等同于国际标准 ISO/IEC 15408,也就是美国、英国、德国、加拿大等国家共同制定的 CC (本文后面也沿用 CC 这个通俗名称代表 GB/T 18336)。

TCSEC 是 80 年代,美国国防部根据军事计算机系统的保密需要,在 70 年代的基础理论研究成果计算机保密模型(Bell & La padula 模型)的基础上制订的,亦称为“橙皮书”。1985 年正式发布。该标准事实上成为了美国国家信息安全评估和等

级划分标准,对世界各国的信息安全标准研究产生了广泛的影响。英国、德国、加拿大等国也先后制定了立足于本国情况的信息安全评估标准。

1991 年,欧洲英、法、德、荷四国国防部门信息安全机构率先联合制定了《信息技术安全评估准则》(ITSEC),并在事实上成为欧盟各国使用的共同评估标准。这为多国共同制定信息安全标准开了先河。为了紧紧把握信息安全产品技术与市场的主导权,美国在欧洲四国出台 ITSEC 之后,立即倡议欧美六国七方(即英、法、德、荷、加五国防务信息安全机构,加上美国国防部国家安全局(NSA)和美国商务部国家标准与技术局(NIST))共同制定一个供欧美各国通用的信息安全评估标准。1993 年至 1996 年,经过四、五年的研究开发,产生了《信息技术安全通用评估准则》,简称 CC 标准。它是在 TCSEC、ITSEC、CTCPEC、FC 等信息安全标准的基础上综合形成的。

为了适应经济全球化的形势要求,在 CC 标准制定出不久,六国七方即推动国际标准化组织(ISO)将 CC 标准纳入国际标准体系。经过多年协商和切磋,国际标准化组织于 1999 年批准 CC 标准以“ISO/IEC 15408-1999”名称正式列入国际标准系列。

图 1 清楚地显示出了 TCSEC、CC 等信息安全标准的历史沿革。

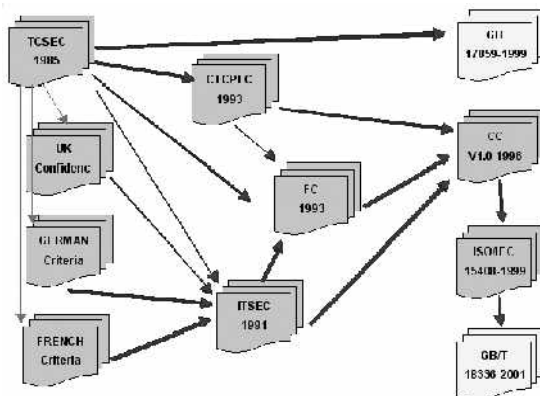


图1 TCSET、CC等信息安全标准的历史沿革示意图

从 TCSEC 和 CC 的传承关系可以清楚地知道, TCSEC 对 CC 的产生具有历史性的贡献。它们之间并不存在矛盾, 只有继承和发展。GB17859 与 GB/T18336 之间关系本质上也保持了 TCSEC 和 CC 之间的这种关系。

二、GB17859 与 GB/T18336 内容侧重不同

从标准的内容上看, TCSEC 主要规范了计算机应用系统和产品的安全要求, 侧重于对保密性的要求, 它把安全分为安全策略、责任、保证和文档 4 个方面及 D、C1、C2、B1、B2、B3、A1 和超 A1 级 8 个安全级别。GB17859 吸取了 TCSEC 的基本思想, 并根据我国的信息安全需要进行了适应性的改进和完善, 其中的主要变化是把计算机信息系统安全保护能力精简为更具可操作性的五个等级。

CC, 全称为 Common Criteria, 其中文意义即“通用准则”, 它是在对 TCSEC、ITSEC、CTCPEC、FC 等一系列安全标准的充分融合、抽象, 从而形成的一个高度浓缩精化的基础性的信息安全标准。CC 标准文本中就作了这样的描述:“(CC) 定义了作为评估信息技术产品和系统安全特性的基础准则”。

与 TCSEC 不同, CC 并未从安全功能方面对产品/系统进行分级, 它的目标是为评估产品/系统是否满足特定安全目标提供通用的方法。针对在安全性评估过程中信息技术产品和系统的安全功能及相应的保证措施, CC 提供了一组通用要求, 使各种独立的安全评估结果具有可比性, 使信息技术安全评估的结果能被更多的人理解。

CC 对自身适用范围主要有两点说明:

(1) CC 可用于具有信息技术安全功能的产品和系统的开发与采购指南;

(2) CC 适用于硬件、固件和软件实现的信息技术安全措施。

CC 中全面地考虑了与信息技术安全性有关的所有因素, 并以安全功能和安全保证的形式提出了这些因素。针对不同的安全产品需求, 可以通过对安全功能和安全保证中部件的选择和组合, 制订出有针对性的“保护轮廓”(PP)和“安全目标”(ST)。通过“保护轮廓”和“安全目标”这两种结构, 可以将 CC 的安全性要求具体应用到各种 IT 产品的开发、生产、测试、评估中。因此 CC 具有非常好的可扩展性和适用性。

总之, CC 是一个开放的、框架性的、基础性的通用安全评估标准。

回过头再看 TCSEC 及相配套的 TNI、TDI 等解释系列, 实质上为信息系统和产品提供了比 CC 更加具体的安全技术和等级划分标准。GB17859 的文本中更明确说明该标准的目的是主要有三个: (1) 为计算机信息系统安全法规的制定和执法部门的监督检查提供依据; (2) 为安全产品的研制提供技术支持; (3) 为安全系统的建设和管理提供技术指导。

由此可见, CC 与 TCSEC 完全是两个层面上的规范, 前者是在后者的基础上发展而来的更高层次的信息安全标准, 后者是一个具有明显的行政管理特征的信息安全技术需求规范。它们之间不存在矛盾或对立, 更没有谁替代谁的问题。GB17859 与 18336 之间的关系也是如此。

综合前面的分析, GB/T18336 和 GB17859 总的来说是“一般规律”和“具体实践”的关系。GB/T18336 为有关的安全标准、指南的制定提供了比较系统、完善的框架, 而 GB17859 直接提供了信息系统与产品的安全等级划分、等级评估的总体技术要求。

当然, 后者由于参照的 TCSEC 标准已有 20 年的历史, 以今天的眼光看, 存在一些明显的不足。但是我国从 90 年代以来, 依据 TCSEC 在国标、军标的制定以及配套的实际产品与系统的评测中作了大量的工作, 已经积累了比较丰富的经验; 同时 GB17859 中体现的等级保护思想在世界范围内得到了广泛的认同和应用, 具有充分的现实意义。

因此, 对于当前的等级保护工作, 正确认识了 GB/T18336 和 GB17859 之间的关系, 我们完全可以在 CC 提供的通用框架下, 充分参照 GB17859 提供的等级保护要求, 结合实际制定出各种具体的 PP (信息安全保护轮廓), 从而快速形成国家等级保护与评估的标准体系, 从标准规范方面为我国信息化应用的健康发展提供有力的安全保证。

参考文献

- [1] Trusted Computer System Evaluation Criteria (Orange Book) December 26, 1985.
- [2] 《计算机信息系统安全保护等级划分准则》GB 17859.
- [3] 《信息技术 安全技术 信息技术安全性评估准则》GB/T 18336.
- [4] 《信息安全产品评估标准综述》. 崔书琨.
- [5] 《等级保护方法》. 吉增瑞.
- [6] 《等级保护通用技术要求与 CC》. 吉增瑞.
- [7] 《安全评估标准介绍》. 闫强. 北京大学.